



NETWORK SECURITY STANDARD



Contents

1. Introduction	3
1.1 Why do we have this standard?	3
1.2 Who does this standard apply to?	3
1.3 Requirement to follow standard	3
1.4 Questions	3
2. Minimum Standards.....	4
Standard Overview	4
2.1 Network Design and Segmentation	4
2.2 Network Access Management.....	5
2.3 Network Management	6
2.4 Network Logging and Monitoring	7
3. Document Management	8
3.1 RACI	8
3.2 Document Control	8
3.3 Document History.....	8
4. Appendix.....	9
A. Glossary.....	9
B. Supporting Policies, Standards and Documentation	10
C. Responsibilities.....	Error! Bookmark not defined.

1. Introduction

1.1 Why do we have this standard?

This network security standard defines the minimum technical security measures that must be met when implementing network security controls within M&S. As this standard only provides minimum measures, they should be exceeded as appropriate depending on the threats and risks that need to be addressed, the sensitivity of the data, and in keeping with latest security enhancements.

1.2 Who does this standard apply to?

This standard is intended for, but not necessarily limited to all colleagues, contractors and third-party service providers of M&S who are involved in network security. It encompasses M&S assets, information systems and/or services including but not limited to firmware, hardware, and/or infrastructure assets that store or process M&S information.

1.3 Requirement to follow standard

This standard describes requirements which help to prevent breaches of information security and has consequences when there are acts of non-compliance, whether deliberate or non-deliberate.

Where non-compliance is identified and / or brought to our attention, the matter will be investigated under the relevant disciplinary procedure and in line with the [Acceptable Use Policy](#).

Where it is determined that the standard was breached, this could result in disciplinary action being taken including, in serious cases, potential dismissal or termination of contingent worker contract.

1.4 Questions

Please contact the M&S Information Security team via email InfoSecComms@marks-and-spencer.com with any questions. For further information visit the Information Security Hub [MNSWORLD > Business Areas > Cyber Security].

2. Minimum Standards

Standard Overview

The following section defines the minimum-security standards that must be achieved when deploying network security controls. The relevant CIS v8.1 safeguard reference is provided against each security measure to indicate which outcome(s) it contributes towards.

Reference	Standard	CIS v8.1 Safeguard
2.1 Network Design and Segmentation		
2.1.1 Network Architecture Documentation and Review		
NET.2.1.1.1	Network architecture diagrams must be documented and maintained.	12.4
NET.2.1.1.2	Network architecture must address, at a minimum: a) Segmentation b) Least privilege c) Availability	12.2
NET.2.1.1.3	Any changes to the network architecture or network assets must be: a) Documented b) Reviewed under the change management process c) Approved before implementation	12.1
NET.2.1.1.4	Documentation must be reviewed and updated annually, or when significant enterprise changes occur.	12.4
NET.2.1.1.5	Access to network architecture diagrams must be restricted to authorised personnel and classified as “M&S Confidential”.	12.4
NET.2.1.1.6	A Network Zone Model must be documented, describing logical and physical segmentation.	12.4
2.1.2 Boundary Protection and External Connectivity		
NET.2.1.2.1	External boundary communications must be monitored and controlled.	12.2
NET.2.1.2.2	Approved connection methods between internal and external networks must be documented and reviewed annually or on change.	12.4
NET.2.1.2.3	Secure use cases and rules must be defined for all boundary protection devices.	12.2
NET.2.1.2.4	Incoming and outgoing traffic across network boundaries must be denied by default.	12.2
NET.2.1.2.5	Firewalls must be deployed at all entry points to DMZs and internal networks.	12.1
2.1.3 Network Segmentation and Isolation		

NET.2.1.3.1	Boundary protection devices must be deployed to isolate M&S's critical information systems and supporting business functions.	12.2
NET.2.1.3.2	Separate networks must be implemented for publicly accessible systems and must be physically or logically segregated from internal networks.	12.2
NET.2.1.3.3	DMZ architectures must be used to maintain segregation between: a) External networks b) Externally exposed DMZ environments c) Internal networks	12.2
NET.2.1.3.4	DMZ services must not have direct access to internal networks and all data flows must be controlled through security gateways.	12.2
NET.2.1.3.5	Only internet accessible equipment must be in the DMZ.	12.2
NET.2.1.3.6	No internet accessible equipment must be in a non-DMZ segment.	12.2
NET.2.1.3.7	Periodic security audits must be conducted on DMZ networks to validate adherence to segmentation.	12.2, 12.1
2.1.4 Secure Configuration and Failover Management		
NET.2.1.4.1	All network devices must be configured to fail securely in the event of an operational failure, preventing unauthorised access to protected systems.	12.2, 12.3
NET.2.1.4.2	Firewall rule reviews must be conducted at least annually.	12.2, 12.3
NET.2.1.4.3	Default deny policies must be enforced for all new network segments.	12.2, 12.3
2.2 Network Access Management		
2.2.1 Secure Authentication and Access Control		
NET.2.2.1.1	Centralised AAA (Authentication, Authorisation and Accounting) must be implemented for all network device access.	12.7
2.2.2 Device and Endpoint Security		
NET.2.2.2.1	All devices used for M&S business and operations must meet defined security requirements before accessing the internal network.	12.3
NET.2.2.2.2	Network Access Control must be provisioned to block access to non-compliant and/or unauthorised devices.	12.3
2.2.3 Remote Access Security		
NET.2.2.3.1	All remote access methods must be documented, reviewed, and approved by Information Security.	12.6
NET.2.2.3.2	All remote user access, must be authenticated using Multi-Factor Authentication (MFA).	12.6
NET.2.2.3.3	Remote access must be routed through an authorised and managed network access control point.	12.6
NET.2.2.3.4	Split tunnelling must be strictly prohibited.	12.6

2.2.4 Virtual Private Network (VPN) Requirements		
NET.2.2.4.1	Secure connections must be enforced for all remote access to internal networks.	12.6
NET.2.2.4.2	Secure connections must: a) Use strong encryption mechanisms b) Approved authentication mechanism c) Be configured to prohibit split tunnelling d) Connections and authentication must be logged	12.6
2.2.5 Privileged Access and Administrative Controls		
NET.2.2.5.1	Execution of privileged commands via remote access must be: a) Permitted only through Privileged Access Management (PAM) solutions b) Restricted to approved users based on business needs c) Limited to secure, encrypted protocols d) Logged and monitored	12.6
NET.2.2.5.2	All privileged access must be time-limited and automatically revoked when no longer needed.	12.6
2.2.6 Wireless Network Security		
NET.2.2.6.1	Wireless access must be secured.	12.6
NET.2.2.6.2	Authentication must be enforced and logged.	12.6
NET.2.2.6.3	SSID networks must be segregated.	12.6
NET.2.2.6.4	Guest wireless networks must be segregated from internal networks and require pre-authorisation.	12.6
2.3 Network Management		
2.3.1 Network Device Inventory and Configuration Management		
NET.2.3.1.1	A centralised inventory of all network devices must be maintained.	12.4
NET.2.3.1.2	Standardised naming conventions must be applied and reviewed periodically.	12.1
NET.2.3.1.3	Baseline configurations must be defined and enforced for all network devices.	12.1
NET.2.3.1.4	Configurations must be backed up.	12.1
2.3.2 Secure Management of Network Devices		
NET.2.3.2.1	All administrative access to information systems managing network and security devices require MFA.	12.2
NET.2.3.2.2	Only authorised personnel are permitted to modify network device configurations.	12.2
NET.2.3.2.3	Default manufacturer passwords must be replaced upon installation.	12.2
NET.2.3.2.4	Vulnerability assessments must be performed monthly at a minimum.	12.2
NET.2.3.2.5	Penetration testing must be performed annually at a minimum.	12.2

NET.2.3.2.6	Vulnerable network devices must be remediated.	12.2
NET.2.3.2.7	Network devices must be configured to enforce secure protocols only.	12.2
2.3.3 Change Management and Patch Compliance		
NET.2.3.3.1	All changes to network devices must follow the M&S Change Management Process.	12.1, 12.3
NET.2.3.3.2	Network infrastructure must be in support and running agreed firmware and operating systems.	12.2
NET.2.3.3.3	Software versions must be reviewed monthly, or more frequently, to verify software support.	12.1, 12.2
NET.2.3.3.4	End-of-Life (EoL) hardware and software must be identified with a plan for treatment agreed with InfoSec.	12.2
2.4 Network Logging and Monitoring		
2.4.1 Log Collection and Retention		
NET.2.4.1.1	Logs must be maintained for all network devices and made available for incidents and investigation.	12.2 13.6
NET.2.4.1.2	Log retention must be aligned with defined regulatory or business requirements.	12.2, 13.6
2.4.2 Traffic Monitoring and Anomaly Detection		
NET.2.4.2.1	Traffic must be analysed for anomalies, unauthorised access and malicious activity.	12.2, 13.6
NET.2.4.2.2	Alerts must be automatically generated for anomalies, unauthorised access and malicious activity.	12.2, 13.6
2.4.3 Intrusion Detection		
NET.2.4.3.1	Wireless Intrusion Detection Systems (WIDS) must be deployed to identify rogue devices.	12.2, 13.8
NET.2.4.3.2	Unauthorised wireless connections must be actively monitored and blocked.	12.2, 13.5, 13.8
NET.2.4.3.3	Network Intrusion Prevention/Detection Systems (NIPS/NIDS) must be deployed to detect and respond to threats.	12.2, 13.3, 13.8
2.4.4 Incident Response and Alerting		
NET.2.4.4.1	Network security events must be evaluated and treated.	12.2, 13.1
NET.2.4.4.2	Network security events must be enriched and correlated with other security telemetry for security incident management.	12.2 13.1

V1.0

3. Document Management

3.1 RACI

R	A	C	I
Head of InfoSec GRC	GRC Compliance Lead	InfoSec Team Subject Matter Experts	Technology Groups Support Centres

3.2 Document Control

Document Reference	Std-25-005
Document Name	M&S Network Security Standard
Document Version	1.0
Approved by	Tom Bolton
Effective Date	2 nd June 2025
Review Period	Annual
Review Date	19/1/2026
Classification	M&S Internal

3.3 Document History

Date	Version	Author	What was changed?
13/03/2025	0.1 (DRAFT)	EY and SMEs	Initial Draft
13/05/2025	1.0	Mike Williams	Minor updates prior to publication

4. Appendix

A. Glossary

Term/Abbreviation	Definition
Network Architecture	The design and structure of a network, including its physical and logical components, protocols, and services.
Network Boundary	The defined perimeter of a network that separates internal resources from external entities.
Internal Network	A private network that is used within an organisation, typically consisting of computers, servers, and other devices that are connected to each other.
External Network	A network that exists outside of an organisation's internal network, typically referring to the internet or other public networks.
MFA (Multi Factor Authentication)	A security mechanism that requires users to provide two or more verification factors to gain access to a system or application.
PAM (Privileged Access Management)	A security framework that controls and monitors access to critical systems and sensitive information by users with elevated privileges.
EoL (End-of-Life)	The stage in a product's lifecycle when it is no longer supported or maintained by the manufacturer.
DMZ (Demilitarized Zone)	A physical or logical subnetwork that contains and exposes an organisation's external-facing services to an untrusted network, typically the internet.
Segmentation	The practice of dividing a network into smaller, distinct segments or subnets to enhance security and performance.
Least Privilege	A security principle that restricts user access rights to the minimum necessary to perform their job functions.
Availability	A key principle of information security that ensures that systems, services, and data are accessible and usable when needed by authorised users.
Network Zone Model	A security architecture framework that categorises network components into different zones based on their security requirements and trust levels.
Remote Access	The ability for users to connect to a network or system from a remote location, typically using secure methods such as Virtual Private Networks (VPNs) or secure shell (SSH).
Firewalls	Security devices or software that monitor and control incoming and outgoing network traffic based on predetermined security rules.
SSID networks	A unique identifier that distinguishes one wireless local area network (WLAN) from another.

B. Supporting Policies, Standards and Documentation

This standard should be read in conjunction with, but not limited to, the following internal documents.

Document Name	Document Location
Network Zone Model	TBC
Network Technology Standards	TBC
Network Device Configuration Baselines	TBC
Wireless Network Security Guidelines	TBC
Remote Access Policy	TBC
Incident Response Playbooks	TBC
Network Monitoring and Logging Standards	TBC
IP Address Management (IPAM) Documentation	TBC
Change Management Procedure	TBC
Business Continuity and Disaster Recovery Plans	TBC
Firewall Ruleset Documentation	TBC